TARMOQ XAVFSIZLIGI

A13. Proxy va WAF vositalarini sozlash

1-VARIANT — Apache reverse proxy, ModSecurity va OWASP CRS

Mashg‘ulot maqsadi. Talaba veb-xizmat oldiga reverse proxy joylashtiradi, ModSecurity va OWASP Core Rule Set (CRS)ni ulaydi, kuzatuv va bloklash rejimlarini taqqoslaydi. Qonuniy so‘rov noto‘g‘ri bloklangan holatni qayta hosil qilib, faqat zarur endpoint va parametrga tegishli istisno yaratadi hamda qolgan himoya saqlanganini tekshiradi.

Senariy. O‘quv portalining backend xizmati faqat serverning loopback manzilida ishlaydi. Windows 11 hostdagi mijoz unga Apache orqali murojaat qiladi. Portal matnli izoh qabul qiladi: “JavaScript darsi” qonuniy matn, ammo ataylab sodda tuzilgan mahalliy qoida uni shubhali deb topadi. Talaba bu noto‘g‘ri qarorni butun WAFni o‘chirmasdan tuzatishi kerak.

Ko‘rsatkich	Ushbu variant
Semestr / hajm	5-semestr; 2 akademik soat
Vaqt	Tayyor obraz va kod matnlari bilan taxminan 80 daqiqa
Xona	30 ta Windows 11 host; har hostda alohida virtual lab
Host	8 yadroli CPU; 32 GB RAM; 1 TB SSD; LAN va Internet
WAF-SRV	Ubuntu Server 24.04 LTS; 2 vCPU, 4 GB RAM, 25 GB disk
Mijoz	Windows 11 host; PowerShell va curl.exe
Vositalar	Apache 2.4, ModSecurity 2.x moduli, paketdagi CRS, Python 3
Natija	Proxy va WAF sozlamalari; 12 ta sinov; loglar va tor istisno

Muhim tushunchalar

- Reverse proxy mijoz so‘rovini oldindan belgilangan backendga uzatadi. Forward proxy esa mijoz tanlagan xizmatga vositachilik qiladi; ushbu variantda reverse proxy ishlatiladi. [1]
- WAF HTTP so‘rovi va qoidalarni solishtiradi. CRS turli veb-hujum belgilarini aniqlovchi umumiy qoidalar to‘plamidir. [2]
- DetectionOnly — qoidalar ishlaydi, lekin bloklash bajarilmaydi; On — rad etish amallari ham qo‘llanadi. [3]
- False positive — qonuniy so‘rovning noto‘g‘ri shubhali deb topilishi. Istisno qoida, parametr va foydalanish joyi bilan chegaralanadi. [4]

Chegara. Sinovlar faqat 10.130.10.0/24 host-only segmentida va zararsiz o‘quv backendida bajariladi. Matndagi XSSga o‘xshash belgilar ma’lumot sifatida ko‘riladi, bajarilmaydi. WAF sinovi real saytga hujum qilish yoki barcha zaifliklardan himoyalanganlikni isbotlash uchun mo‘ljallanmagan.

1. Muhitni tayyorlash va manzillash

1.1. Darsdan oldingi tayyorgarlik

Ubuntu Server 24.04 LTS toza VMiga vaqtincha NAT adapter orqali paketlarni o‘rnating. Paketlar rasmiy Ubuntu omboridan olinadi; tashqi tasodifiy skript yoki qo‘shimcha pullik xizmat talab qilinmaydi. Paket versiyalarini qayd eting: yangilanishlar sabab CRSning kichik versiyasi farq qilishi mumkin.

```
sudo apt update
sudo apt install -y apache2 libapache2-mod-security2  modsecurity-crs python3 curl nano
sudo systemctl stop apache2
dpkg-query -W apache2 libapache2-mod-security2 modsecurity-crs
# Paket taqdim etgan CRS fayllarini ko'rish:
dpkg -L modsecurity-crs | grep -E 'crs-setup|rules/.*conf$'
```

Agar paket topilmasa, Ubuntu rasmiy Universe komponenti yoqilganini tekshiring; zarur bo‘lsa sudo add-apt-repository universe va sudo apt update bajariladi. Apache uchun libapache2-mod-security2 ishlatiladi; bu ModSecurity 2.x yo‘li. Nginx uchun mo‘ljallangan alohida 3.x connector ko‘rsatmalarini aralashtirmang. [2]

1.2. Host-only segmentni sozlash

Obyekt	IPv4 / maska	Xizmat
Windows host	10.130.10.1/24	curl.exe mijozi
WAF-SRV lab adapteri	10.130.10.10/24	Apache TCP 80
WAF-SRV loopback	127.0.0.1	Python backend TCP 8080

1. VirtualBox Network Managerda host-only adapter yarating: host IP 10.130.10.1/24, DHCP o‘chiq. WAF-SRVni shu adapterga ulang.
2. VMwareda Virtual Network Editor orqali alohida Host-only VMnet yarating: subnet 10.130.10.0/24; host adapteri yoqilgan, DHCP o‘chiq. Windows virtual adapter IPsi 10.130.10.1 bo‘lsin.
3. Paketlar o‘rnatilgach NAT kabelini uzing. Bridged, port forwarding yoki hostdagi tarmoq ko‘prigi ishlatilmaydi. Hostning jismoniy Ethernet/Wi-Fi adapterini o‘zgartirmang.
4. Hypervisor guest tools va A13 nomli shared folderni oldindan sozlang; u dalillarni hostga olish uchun kerak. A13-base snapshot yarating.

Har hostdagi virtual segment alohida bo‘lgani uchun 30 talaba bir xil IP rejasidan foydalanishi mumkin. O‘qituvchi subnet xona LANi yoki VPN bilan to‘qnashmasligini tekshiradi. Host-only tarmoq jismoniy hostni ham o‘z ichiga oladi; Internet shlyuzi kerak emas.

1.3. Ubuntu konsolida lab IPsi

```
sudo -i
ip -br link
# enp0s8 o'rniga MAC bo'yicha topilgan lab interfeysini yozing:
LAB_IF=enp0s8
ip link set "$LAB_IF" up
ip addr replace 10.130.10.10/24 dev "$LAB_IF"
ip -br addr
mkdir -p /opt/a13/evidence
```

Bu IP sozlama vaqtinchalik: tajriba davomida VMni reboot qilmang. Keyingi Linux buyruqlari shu root konsolida bajariladi. Windows buyruqlari alohida “Windows HOST” deb ko‘rsatilgan.

2. O‘quv backendini tayyorlash

2.1. Backend kodi

Backend faqat JSON javob qaytaradi, qabul qilingan matnni SQL, shell yoki HTML sifatida bajarmaydi. /redirect manzili proxy javob sarlavhasini tuzatishini tekshirish uchun 302 qaytaradi. Faylni quyidagicha yarating:

```
cat > /opt/a13/backend.py <<'APP'
from http.server import BaseHTTPRequestHandler, ThreadingHTTPServer
from urllib.parse import urlsplit, parse_qs
import json
class App(BaseHTTPRequestHandler):
    def answer(self, body=""):
        path = urlsplit(self.path)
        if path.path == "/redirect":
            self.send_response(302)
            self.send_header("Location", "http://127.0.0.1:8080/landing")
            self.send_header("Content-Length", "0")
            self.end_headers()
            return
        data = {"service": "A13-backend", "path": path.path,
                "query": parse_qs(path.query), "body": body}
        raw = json.dumps(data, ensure_ascii=True).encode()
        self.send_response(200)
        self.send_header("Content-Type", "application/json")
        self.send_header("X-Content-Type-Options", "nosniff")
        self.send_header("Content-Length", str(len(raw)))
        self.end_headers()
        self.wfile.write(raw)
    def do_GET(self):
        self.answer()
    def do_POST(self):
        size = int(self.headers.get("Content-Length", "0"))
        if size > 131072:
            self.send_error(413)
            return
        self.answer(self.rfile.read(size).decode("utf-8", "replace"))
    def log_message(self, fmt, *args):
        case = self.headers.get("X-A13-Case", "-")
        print(case, fmt % args, flush=True)
ThreadingHTTPServer(("127.0.0.1", 8080), App).serve_forever()
APP
chmod 755 /opt/a13
chmod 644 /opt/a13/backend.py
python3 -m py_compile /opt/a13/backend.py
```

2.2. Xizmatni ishga tushirish

```
cat > /etc/systemd/system/a13-backend.service <<'UNIT'
[Unit]
Description=A13 teaching backend
[Service]
User=www-data
ExecStart=/usr/bin/python3 /opt/a13/backend.py
NoNewPrivileges=true
PrivateTmp=true
Restart=on-failure
UNIT
systemctl daemon-reload
systemctl start a13-backend
curl --noproxy '*' --max-time 3 http://127.0.0.1:8080/health
ss -lntp 'sport = :8080'
```

Natija: JSONda service=A13-backend; tinglovchi faqat 127.0.0.1:8080. Python server ishlab chiqarish uchun emas. Uni 0.0.0.0 ga bog‘lamang: aks holda WAFni chetlab backendga yetish yo‘li ochilishi mumkin.

3. Apache reverse proxyni sozlash

3.1. Zaxira va kerakli modullar

Buyruqlar faqat yangi o‘quv VMiga tegishli. Mavjud saytli serverda ports.conf va security2.conf ni bu tarzda almashtirish mumkin emas. Bu labda barcha o‘zgartirishdan oldin konfiguratsiya nusxasi saqlanadi.

```
cp -a /etc/apache2 /opt/a13/apache2-before
cp -a /etc/modsecurity /opt/a13/modsecurity-before
a2enmod proxy proxy_http headers unique_id security2
a2dissite 000-default
printf 'Listen 10.130.10.10:80\n' > /etc/apache2/ports.conf
cat > /etc/apache2/sites-available/a13.conf <<'VHOST'
<VirtualHost 10.130.10.10:80>
    ServerName a13.test
    ProxyRequests Off
    ProxyPreserveHost On
    ProxyPass / http://127.0.0.1:8080/ connectiontimeout=2 timeout=5
    ProxyPassReverse / http://127.0.0.1:8080/
    RequestHeader unset X-Forwarded-For
    RequestHeader unset X-Real-IP
    Header always set X-A13-Gateway "apache-waf"
    ErrorLog /var/log/apache2/a13-error.log
    LogFormat "%a %t \"%r\" %>s %{X-A13-Case}i %{UNIQUE_ID}e" a13
    CustomLog /var/log/apache2/a13-access.log a13
</VirtualHost>
VHOST
a2ensite a13
apache2ctl configtest
systemctl restart apache2
apache2ctl -M | grep -E 'proxy|security2|unique_id|headers'
apache2ctl -S
```

Syntax OK chiqishi kerak. Agar foydalanuvchi nusxalashida LogFormat ichidagi qo‘shtirnoqlar buzilsa, matnni shu kod bilan solishtiring. ServerName haqidagi FQDN ogohlantirishi sintaksis xatosi bilan bir xil emas.

3.2. So‘rov yo‘lini tushuntirish

Mijoz TCP 80 orqali Apachega ulanadi. Apache HTTP so‘rovini lokal TCP 8080 backendga uzatadi; javob mijozga Apache orqali qaytadi. ProxyPassReverse backenddagi Location kabi tegishli javob sarlavhalarini tashqi manzilga moslashtiradi; HTML sahifa ichidagi barcha URLlarni avtomatik qayta yozmaydi. ProxyRequests Off reverse proxy ishlashiga to‘sqinlik qilmaydi. [1]

Host Windows proxy sozlamalarini o‘zgartirmang. curl.exe ishlatish PowerShelldagi curl taxallusi bilan chalkashishni bartaraf qiladi. Windowsning yangi PowerShell oynasida $u o‘zgaruvchisini qayta belgilang.

```
# Windows HOST — PowerShell:
$u = 'http://10.130.10.10'
curl.exe --noproxy "*" --max-time 5 -i "$u/health"
curl.exe --noproxy "*" --max-time 5 -i "$u/redirect"
```

Birinchi javob 200 va X-A13-Gateway: apache-waf sarlavhasini beradi. Ikkinchisi 302; Location ichida 127.0.0.1:8080 qolmasligi kerak. -L ishlatilmagani sabab redirect avtomatik kuzatilmaydi. HTTP ajratilgan lab uchun; real portalda TLS ham sozlanadi.

4. ModSecurity va CRSni ulash

4.1. Konfiguratsiya fayllarini tekshirish

Quyidagi yo‘llar Ubuntu paketlari bilan mo‘ljallangan. Birortasi yo‘q bo‘lsa davom etmang: dpkg -L natijasidan haqiqiy yo‘lni topib, Include qatorlarini moslashtiring. CRSni paketdan va GitHubdan bir vaqtda qo‘shish kerak emas.

```
test -f /etc/modsecurity/modsecurity.conf-recommended
test -f /etc/modsecurity/crs/crs-setup.conf
ls /usr/share/modsecurity-crs/rules/*.conf | head
cp /etc/modsecurity/modsecurity.conf-recommended  /etc/modsecurity/modsecurity.conf
sed -i 's/^SecRuleEngine .*/SecRuleEngine DetectionOnly/'  /etc/modsecurity/modsecurity.conf
# Runtime istisnolar fayli hozircha bo'sh:
printf '# A13 runtime exclusions\n' > /etc/modsecurity/a13-before.conf
# Mahalliy qoidalar keyingi sahifada yoziladi:
printf '# A13 local rules\n' > /etc/modsecurity/a13-local.conf
```

4.2. Qoidalarning yuklanish tartibi

security2.conf quyidagi aniq Include ro‘yxati bilan almashtiriladi. Shu fayldagi eski wildcard va *.load satrlari bilan birga qoldirmang: bu bir xil CRS qoidalarini ikki marta yuklashi mumkin. Zaxira 3.1-bo‘limda olingan.

```
cat > /etc/apache2/mods-available/security2.conf <<'WAF'
<IfModule security2_module>
    SecDataDir /var/cache/modsecurity
    Include /etc/modsecurity/modsecurity.conf
    SecAuditEngine RelevantOnly
    SecAuditLogType Serial
    SecAuditLog /var/log/apache2/a13-audit.log
    SecAuditLogParts ABFHZ
    Include /etc/modsecurity/a13-before.conf
    Include /etc/modsecurity/crs/crs-setup.conf
    Include /usr/share/modsecurity-crs/rules/*.conf
    Include /etc/modsecurity/a13-local.conf
</IfModule>
WAF
apache2ctl configtest
apache2ctl -t -D DUMP_INCLUDES > /opt/a13/evidence/includes.txt
grep -E 'modsecurity|crs' /opt/a13/evidence/includes.txt
systemctl reload apache2
```

CRS setup qoidalardan oldin, runtime istisno esa tekshiriladigan qoidadan oldin yuklanadi. Qoidalar turli fazalarda bajariladi; fayldagi tartibning o‘zi fazalarni almashtirmaydi. [2, 4]

4.3. So‘rov tanasi va audit

modsecurity.conf ichida SecRequestBodyAccess On ekanini tekshiring: POSTdagi form maydonlarini tahlil qilish uchun kerak. Bu mashg‘ulot application/x-www-form-urlencoded bilan ishlaydi. JSON parser sozlamasi bu variantning asosiy sinoviga kiritilmagan.

```
grep -E '^SecRuleEngine|^SecRequestBodyAccess'  /etc/modsecurity/modsecurity.conf
```

Auditdagi A — tranzaksiya boshi, B — so‘rov sarlavhalari, F — javob sarlavhalari, H — qoida xabarlari, Z — yakun. C qismi kiritilmagan bo‘lsa ham Hdagi matched data kiritma parchasini saqlashi mumkin. Shu sababli faqat sun’iy matn yuboring, haqiqiy parol yoki token ishlatmang. [3]

5. Mahalliy qoidalar va kuzatuv rejimi

5.1. Ikki o‘quv qoidasini qo‘shish

1001300 identifikatorli qoida WAF dvigatelini oddiy marker bilan tekshiradi. 1001301 esa ataylab juda sodda yozilgan: comment maydonida script bo‘lsa rad etadi. Bu ikkinchi qoida sifatli XSS himoyasi sifatida tavsiya etilmaydi; undan false positive va tor istisnoni o‘rganish uchun foydalaniladi.

```
cat > /etc/modsecurity/a13-local.conf <<'RULES'
SecRule REQUEST_HEADERS:X-A13-Test "@streq block-me" \
 "id:1001300,phase:1,t:none,deny,status:403,log,msg:'A13 marker'"
SecRule ARGS:comment "@contains script" \
 "id:1001301,phase:2,t:none,t:lowercase,deny,status:403,log,msg:'A13 broad comment rule'"
RULES
apache2ctl configtest && systemctl reload apache2
```

IDlar ushbu toza lab uchun tanlangan va boshqa qoidalarga takrorlanmasligi kerak. Birinchi qoida sarlavhani 1-fazada, ikkinchisi form parametrini 2-fazada ko‘radi. DetectionOnly holatida deny qayd etiladi, amalda bloklash bajarilmaydi. [3]

5.2. T1–T3: kuzatuv rejimida sinash

Windows HOST PowerShellda har buyruqni bir marta bajaring. X-A13-Case sinov nomi loglarni topishga yordam beradi; u autentifikatsiya vositasi emas. Javoblarni skrinshot yoki terminal nusxasi bilan saqlang.

```
$u = 'http://10.130.10.10'
# T1: oddiy so'rov
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T1" "$u/health"
# T2: mahalliy qoida markeri
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T2" `
 -H "X-A13-Test: block-me" "$u/health"
# T3: CRSga XSS belgili, bajarilmaydigan matn
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T3" `
 -G --data-urlencode "q=<script>alert(1)</script>" "$u/search"
```

Kutiladigan natija: T1, T2 va T3 — 200. T2 uchun 1001300; T3 uchun 941xxx oilasidagi CRS aniqlash qoidalari logda ko‘rinishi kutiladi. Aniq IDlar o‘rnatilgan CRS versiyasiga qarab farq qilishi mumkin. T3 backendga yetgani JSONda matn ko‘rinishi yoki backend jurnalida tasdiqlanadi.

```
# Ubuntu root konsoli:
grep -E '1001300|941[0-9]{3}|949110' /var/log/apache2/a13-error.log
journalctl -u a13-backend --since '30 minutes ago' --no-pager
```

T3 uchun CRS qoidasi umuman ko‘rinmasa bloklash bosqichiga shoshilmang: DUMP_INCLUDES va modullarni tekshiring. Faqat mahalliy markerning ishlashi CRS to‘g‘ri yuklanganini isbotlamaydi.

6. Bloklash rejimi va dalillarni bog‘lash

6.1. WAFni faol rejimga o‘tkazish

```
# Ubuntu root konsoli:
cp /etc/modsecurity/modsecurity.conf /opt/a13/modsecurity-detect.conf
sed -i 's/^SecRuleEngine .*/SecRuleEngine On/' \
 /etc/modsecurity/modsecurity.conf
apache2ctl configtest && systemctl reload apache2
grep '^SecRuleEngine' /etc/modsecurity/modsecurity.conf
```

Syntax OK va SecRuleEngine On chiqsin. reload muvaffaqiyatsiz bo‘lsa diskdagi fayl bilan ishlayotgan server holati bir xil bo‘lmasligi mumkin; xatoni tuzating. 6.2-bo‘limni faqat muvaffaqiyatli reloaddan keyin bajaring.

6.2. T4–T6: shu so‘rovlarni qayta tekshirish

```
# Windows HOST:
$u = 'http://10.130.10.10'
# T4: oddiy so'rov hali ishlashi kerak
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T4" "$u/health"
# T5: marker bloklanadi
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T5" `
 -H "X-A13-Test: block-me" "$u/health"
# T6: CRS aniqlagan kiritma bloklanadi
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T6" `
 -G --data-urlencode "q=<script>alert(1)</script>" "$u/search"
```

Kutiladigan natija: T4 — 200; T5 — 403, ID 1001300; T6 — 403, XSS aniqlash qoidalari va odatda 949110 bloklash bahosi. 949110 o‘zi XSSni aniqlash imzosi emas; u yig‘ilgan kiruvchi anomaliya bali chegaradan oshganini bildiradi. CRSning qoida signali va yakuniy bloklash qarorini alohida ko‘rsating. [5]

6.3. Access, WAF va backend loglari

```
# Ubuntu root konsoli:
tail -n 12 /var/log/apache2/a13-access.log
grep -E '1001300|941[0-9]{3}|949110' /var/log/apache2/a13-error.log
tail -n 100 /var/log/apache2/a13-audit.log
journalctl -u a13-backend --since '30 minutes ago' --no-pager
```

Access logdagi oxirgi maydon UNIQUE_IDni oling; error/audit ichida shu identifikatorni qidiring. Auditdagi sarlavhalar orasida X-A13-Case ham ko‘rinadi. T4 backendga yetadi, T5/T6 yetmasligi kerak. Faqat 403 ko‘rish yetarli emas: uni rule ID, URI, vaqt va tranzaksiya identifikatori bilan bog‘lang.

Backendning yo‘qligi yoki timeout 502/503 kabi proxy xatolarini keltirishi mumkin. Ularni avtomatik ravishda WAF bloklashi deb baholamang. 200 javob ham kiritma xavfsizligini to‘liq isbotlamaydi; bu labda u faqat so‘rov qaysi qatlamdan o‘tganini ko‘rsatadi.

7. False positive holatini tor istisno bilan tuzatish

7.1. T7: qonuniy form matni noto‘g‘ri bloklanadi

```
# Windows HOST; $u avvalgi qiymatda:
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T7" `
 --data-urlencode "comment=JavaScript darsi" "$u/submit"
```

Kutiladigan natija: 403, 1001301 qoidasining xabari. Bu haqiqiy CRS false positive haqidagi da’vo emas: muammo ataylab kiritilgan mahalliy qoidada. Talaba “script” bo‘lagi qonuniy JavaScript so‘zida ham borligini izohlaydi.

7.2. Faqat POST /submit uchun comment maydonini ajratish

```
# Ubuntu root konsoli:
cp /etc/modsecurity/a13-before.conf /opt/a13/exclusions-before.conf
cat > /etc/modsecurity/a13-before.conf <<'EXCLUDE'
SecRule REQUEST_URI "@streq /submit" \
 "id:1001302,phase:1,t:none,pass,nolog,chain"
    SecRule REQUEST_METHOD "@streq POST" \
      "t:none,ctl:ruleRemoveTargetById=1001301;ARGS:comment"
EXCLUDE
apache2ctl configtest && systemctl reload apache2
```

Istisno faqat aniq /submit URI va POST usuli mos bo‘lganda, faqat 1001301 qoidasining ARGS:comment nishonini olib tashlaydi. Query stringli /submit?x=1 bu aniq URIga teng emas. CRSning 941xxx qoidalari saqlanadi. Runtime istisno fazasi va joyi sababli tekshiriladigan mahalliy qoidadan oldin ishlaydi. [3, 4]

7.3. T8–T10: tuzatish va himoya chegarasini tekshirish

```
# Windows HOST:
# T8: aynan ruxsat berilgan qonuniy matn
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T8" `
 --data-urlencode "comment=JavaScript darsi" "$u/submit"
# T9: boshqa endpointga bu istisno tatbiq etilmaydi
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T9" `
 --data-urlencode "comment=JavaScript darsi" "$u/other"
# T10: /submitda ham CRS XSS tekshiruvi qolgan
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T10" `
 --data-urlencode "comment=<script>alert(1)</script>" "$u/submit"
```

Kutiladigan natija: T8 — 200; T9 — 403 va 1001301; T10 — 403 va CRS qoidalari. T10ning 403 javobini faqat statusga qarab qabul qilmang: 1001301dan mustaqil CRS signali borligini tasdiqlang. T8 403 bo‘lsa URI/usul mosligi, Include tartibi va haqiqiy rule IDni tekshiring.

Real ilovada bunday istisno kiritishdan oldin commentning saqlanishi va ekranga chiqarilishi xavfsizligi tekshiriladi. WAF istisnosi server tomonidagi tekshiruv va chiqishni kontekstga mos kodlash o‘rnini bosmaydi.

8. Proxy yo‘li va natijalarni rasmiylashtirish

8.1. T11–T12: originni yashirish va redirect

```
# Windows HOST:
# T11: backendga bevosita ulanish bajarilmasligi kerak
Test-NetConnection 10.130.10.10 -Port 8080
# T12: reverse proxy Location sarlavhasini tuzatadi
curl.exe --noproxy "*" --max-time 5 -i -H "X-A13-Case: T12" "$u/redirect"
```

T11: TcpTestSucceeded=False; buni Ubuntu ss natijasidagi 127.0.0.1:8080 bilan birga qayd eting. T12: 302 va tashqi proxy manziliga mos Location; ichki 127.0.0.1:8080 mijozga uzatilmasin. Bitta ulanish muvaffaqiyatsizligi o‘z-o‘zidan qaysi himoya mexanizmi ishlaganini ko‘rsatmaydi.

8.2. To‘ldiriladigan natija jadvali

ID	Holat / kiritma	Kutilgan	Amaldagi	Asosiy dalil
T1	DetectionOnly; normal	200	____	Access + backend
T2	DetectionOnly; marker	200	____	1001300 logda
T3	DetectionOnly; XSS belgisi	200	____	CRS signali + backend
T4	On; normal	200	____	Backendga yetgan
T5	On; marker	403	____	1001300; backendga yo‘q
T6	On; XSS belgisi	403	____	CRS aniqlash/bloklash
T7	POST /submit; qonuniy comment	403	____	1001301 false positive
T8	Istisnodan keyin T7	200	____	Backendga yetgan
T9	POST /other; shu comment	403	____	1001301 ishlamoqda
T10	POST /submit; XSS belgisi	403	____	CRS himoyasi saqlangan
T11	Backend TCP 8080	Ulanmaydi	____	ss + port testi
T12	GET /redirect	302	____	Location qayta yozilgan

8.3. Bitta bloklangan tranzaksiya kartasi

Maydon	Talaba to‘ldiradi
Test ID, sana/vaqt va vaqt zonasi	_____
Manba IP; HTTP usuli va URI	_____
Access logdagi UNIQUE_ID	_____
Aniqlash qoidasining IDsi va xabari	_____
Bloklash qoidasi yoki deny amali	_____
HTTP status; backendga yetgan/yetmagan	_____

Natijalarni oldindan kutilgan qiymatlar bilan to‘ldirmang. Noto‘g‘ri holat chiqsa uning sababi va tuzatishdan keyingi qayta sinovni alohida yozing. Windows va Ubuntu vaqt zonalarini ko‘rsating; vaqt bo‘yicha solishtirganda farqni hisobga oling.

9. 1-variant topshirig‘i va topshiriladigan dalillar

1. WAF-SRVni host-only segmentga ulang, lab IPni belgilang, dastur versiyalari va virtual adapter holatini qayd eting.
2. Python backendni alohida systemd xizmatida ishlating. U faqat loopbackda tinglayotganini ko‘rsating.
3. Apache reverse proxyni sozlang. ProxyRequests Off, ProxyPass va ProxyPassReverse vazifalarini tushuntiring; 200 va redirect javoblarini tekshiring.
4. ModSecurity asosiy konfiguratsiyasi, CRS setup va qoidalarni bir martadan yuklang. DUMP_INCLUDES bilan tartibni dalillang.
5. T1–T6 ni kuzatuv hamda faol rejimlarda bajaring. Bir xil kiritmaning turli rejimdagi HTTP statusi va backendga yetishini taqqoslang.
6. T7 false positive sababini toping; faqat POST /submit va commentga tegishli runtime istisno yozing.
7. T8–T10 orqali qonuniy so‘rov o‘tishi, boshqa endpoint va CRS himoyasi saqlanishini tekshiring.
8. T11–T12 ni bajaring, natija jadvali va bitta bloklangan tranzaksiya kartasini to‘ldiring.

9.1. Skrinshot va fayllar

- S1: host-only sozlamasi, Ubuntu IP va paket versiyalari; S2: 80/8080 tinglovchilari, apache2ctl configtest va -M.
- S3: DUMP_INCLUDESdagi CRS va lokal qoidalar; S4: kuzatuvdagi 200 javob bilan birga rule ID.
- S5: faol rejimdagi 403, shu tranzaksiyaning access/error/audit dalili; S6: T8/T9/T10 taqqoslanishi.
- S7: backend porti yopiq va redirect sarlavhasi to‘g‘ri; to‘ldirilgan 12 qatorli natija jadvali.
- Konfiguratsiyalar: a13.conf, security2.conf, modsecurity.conf, a13-before.conf, a13-local.conf; backend.py va xizmat fayli.
- Access/error/audit loglari, backend jurnalining faqat ushbu mashg‘ulotga tegishli qismi; maxfiy qiymatlarsiz hisobot.

9.2. Dalillarni yig‘ish — Ubuntu

```
cp /etc/apache2/sites-available/a13.conf /opt/a13/evidence/
cp /etc/apache2/mods-available/security2.conf /opt/a13/evidence/
cp /etc/modsecurity/modsecurity.conf /opt/a13/evidence/
cp /etc/modsecurity/a13-*.conf /opt/a13/evidence/
cp /opt/a13/backend.py /opt/a13/evidence/
cp /etc/systemd/system/a13-backend.service /opt/a13/evidence/
cp /var/log/apache2/a13-*.log /opt/a13/evidence/
journalctl -u a13-backend --since '90 minutes ago' --no-pager \
 > /opt/a13/evidence/backend-journal.txt
dpkg-query -W apache2 libapache2-mod-security2 modsecurity-crs \
 > /opt/a13/evidence/versions.txt
```

Fayllarni oldindan sozlangan A13 shared folder orqali hostga ko‘chiring. 6–8 gaplik xulosada proxy yo‘li, WAF qarori, false positive, istisno chegarasi va qolgan xavflarni o‘z dalillaringizga tayanib tushuntiring.

10. Nosozliklarni aniqlash va qaytarish

Belgi	Ehtimoliy sabab	Tekshirish / tuzatish
Apache ishga tushmaydi	IP noto‘g‘ri yoki sintaksis xatosi	ip -br addr; configtest; journalctl -u apache2
Duplicate rule ID	CRS yoki lokal fayl ikki marta Include qilingan	DUMP_INCLUDES; eski *.load va yangi Include birga qolmaganini tekshirish
Marker 200, On yozilgan	Reload xato yoki boshqa konfiguratsiya amal qilmoqda	configtest, servis logi, boshqa SecRuleEngine satrlari
Marker blok, XSS esa 200	CRS yuklanmagan yoki siyosat o‘zgargan	CRS include, 941xxx qoidalari va paketdagi setupni tekshirish
POST tekshirilmaydi	Request body o‘qilishi o‘chirilgan	SecRequestBodyAccess On; form Content-Type
T8 ham 403	Istisno mos emas yoki boshqa qoida ishlagan	Rule ID, POST, aniq /submit, a13-before tartibi
T10 200	Juda keng istisno yoki CRS ishlamaydi	Istisnoni qaytarish; CRS signali topilmaguncha sinovni o‘tgan deb baholamaslik
502/503	Backend to‘xtagan yoki port xato	systemctl status a13-backend; curl loopback; ProxyPass

10.1. Istisnoni va rejimni qaytarish

Muammo bo‘lsa avval faqat yangi istisnoni qaytaring. Kuzatuv rejimiga qaytish bu laboratoriyada tekshiruvni davom ettirish uchun; real xizmatda bunday qaror himoya ta’siri bilan baholanadi.

```
cp /opt/a13/exclusions-before.conf /etc/modsecurity/a13-before.conf
apache2ctl configtest && systemctl reload apache2
# Zarur bo'lsa avvalgi DetectionOnly konfiguratsiyasi:
cp /opt/a13/modsecurity-detect.conf /etc/modsecurity/modsecurity.conf
apache2ctl configtest && systemctl reload apache2
```

10.2. Mashg‘ulotni tugatish

```
# Dalillar hostga olingandan keyin:
systemctl stop apache2 a13-backend
ss -lntp
# A13-base snapshotga qaytish keyingi ish uchun tavsiya etiladi.
```

Snapshotga qaytish VM ichidagi dalillarni yo‘qotishi mumkin; avval eksportni tekshiring. Paket fayllarini yoki tizim kataloglarini ommaviy o‘chirish talab qilinmaydi. Faqat sinov xizmatlarini to‘xtatib qo‘yish ham labni xavfsiz yakunlash uchun yetarli.

Qabul qilish chegarasi

Mahalliy qoida, CRS va proxy mustaqil tekshiriladi: marker ishlashi CRSni; CRS bloklashi backend porti yopilganini; 200 javob esa ilovaning barcha zaifliklari tuzatilganini isbotlamaydi. Hisobotda shu uch dalil qatlamini aralashtirmang.

11. Vaqt taqsimoti va baholash

11.1. Tavsiya etilgan 80 daqiqa

Bosqich	Daqiqa	Natija
Muhit va backendni tekshirish	10	IP, loopback tinglovchi, JSON
Reverse proxyni sozlash	15	200, gateway sarlavhasi, redirect
WAF va CRSni ulash	15	Modullar, include tartibi, kuzatuv
Faol rejim va loglar	10	T1–T6 taqqoslanishi
False positive va tor istisno	15	T7–T10; himoya saqlangan
Yakuniy sinov, hisobot va himoya	15	T11–T12, jadval va xulosa
Jami	80	Paket va kod matnlari oldindan tayyor

OT/paketlarni o‘rnatish va uzun kod matnlarini qo‘lda terish bu vaqtga to‘liq kiritilmagan. O‘qituvchi bazaviy obraz va nusxalashga tayyor kodlarni oldindan taqdim etsa, 80 daqiqa amaliy ish va tushuntirishga sarflanadi. Zarur bo‘lsa vaqt uzaytiriladi.

11.2. Baholash mezoni — 10 ball

Mezon	Ball	To‘liq ball uchun talab
Muhit va backend	1	Ajratilgan tarmoq, loopback, xizmat ishlaydi
Reverse proxy	2	Yo‘naltirish, ProxyRequests Off, redirect va origin testi
WAF / CRS ulanishi	2	Bir martalik yuklash, kuzatuv/faol rejim, haqiqiy CRS dalili
Tor istisno	2	T8 o‘tadi; T9/T10 bloklanadi; qoida/parametr/URI/usul chegarasi
Log va tahlil	2	12 sinov jadvali, rule ID va UNIQUE_ID bilan korrelyatsiya
Hisobot va himoya	1	Dalillar, mustaqil izoh va cheklovlarni anglash

11.3. Qisqa nazorat savollari

1. Forward va reverse proxyning asosiy farqi nimada? Nega bu ishda ProxyRequests On kerak emas?
2. ProxyPassReverse qaysi javob qismini tuzatadi? HTMLdagi barcha URLlarni o‘zgartiradimi?
3. DetectionOnly holatida WAF xabari chiqib, so‘rov 200 olishi nimani anglatadi?
4. Mahalliy 1001300 qoidasining ishlashi nega CRS ishlayotganini isbotlamaydi?
5. 941xxx aniqlash qoidasi bilan 949110 bloklash tekshiruvi qanday farqlanadi?
6. POST tanasini WAF tahlil qilishi uchun qaysi asosiy sozlama kerak?
7. 1001302 istisnosi qaysi usul, URI, qoida va parametr bilan cheklangan?
8. Nega T8ning 200 natijasidan keyin T9 va T10ni ham bajarish kerak?
9. 403ni WAFga bog‘lash uchun statusdan tashqari qanday dalillar zarur?
10. WAFni o‘chirib false positivni “tuzatish” qanday himoya yo‘qotishiga olib keladi?

12. Talqin uchun kalit va rasmiy manbalar

12.1. O‘qituvchi uchun qisqa kalit

Asosiy natija ketma-ketligi: T1/T2/T3 — 200; T4 — 200; T5/T6 — 403; T7 — 403; tor istisnodan keyin T8 — 200, T9/T10 — 403; T11 — TCP ulanishi bajarilmaydi; T12 — tashqi manzilga mos Location bilan 302. Bu kutiladigan holatlar; talaba amaldagi sonlar va loglarni o‘zi keltiradi.

False positive sababi: 1001301 commentni kichik harfga o‘tkazib, script qatorini izlaydi. JavaScript ham shu bo‘lakni o‘z ichiga oladi. Istisno faqat POST /submit tranzaksiyasida commentni shu bitta qoidadan chiqaradi. CRS qoidalarini o‘chirmagani uchun T10dagi XSS belgisi hali aniqlanadi.

Proxy dalili: javobdagi gateway sarlavhasi, access log, backend JSONi va redirect. Origin chegarasi: 8080 faqat loopbackda. WAF dalili: ayni tranzaksiya uchun qoida IDsi, yakuniy status va backendga yetmaganlik. Ularning har biri o‘z vazifasini tasdiqlaydi.

12.2. Qo‘shimcha tahlil — vaqt qolsa

- POST /submit?x=1 qonuniy comment bilan yuborilsa, aniq URI istisnosi ishlaydimi? Avval taxmin qiling; sababini qoidaning @streq operatori bilan tushuntiring.
- Ilova bir nechta endpoint yoki JSON tanasi ishlatsa, istisno va body parserni qanday qayta baholash kerakligini yozing.
- Real portal uchun TLS tugatiladigan nuqta, ishonchli proksi IP manbalari, loglarni saqlash muddati va WAF yangilanishidan keyingi regressiya sinovlarini rejalashtiring.

12.3. Foydalanilgan rasmiy manbalar

[1] Apache HTTP Server 2.4 — mod_proxy: ProxyRequests, ProxyPass va ProxyPassReverse. https://httpd.apache.org/docs/2.4/mod/mod_proxy.html

[2] OWASP CRS — Extended Install: dvigatel, asosiy konfiguratsiya va qoidalarni yuklash. https://coreruleset.org/docs/1-getting-started/1-2-extended_install/

[3] OWASP ModSecurity — Reference Manual (v2.x): SecRuleEngine, request body, audit va ctl amallari. https://github.com/owasp-modsecurity/ModSecurity/wiki/Reference-Manual-(v2.x)

[4] OWASP CRS — False Positives and Tuning: tor istisnolar va bajarilish tartibi. https://coreruleset.org/docs/2-how-crs-works/2-3-false-positives-and-tuning/

[5] OWASP CRS — Anomaly Scoring: aniqlash ballari va bloklash chegarasi. https://coreruleset.org/docs/2-how-crs-works/2-1-anomaly_scoring/

Yakuniy qayd. Ish yakunida talaba faqat tayyor sozlamani ko‘chirish bilan cheklanmaydi: so‘rov qayerdan o‘tganini, nima sababdan bloklanganini va istisno aynan qaysi himoya doirasini o‘zgartirganini dalillar bilan tushuntiradi.